

Homework 1

Security Governance a.y. 24-25

Scarselli Ilaria, 1918975 - scarselli.1918975@studenti.uniroma1.it

January, 2025

Contents

1	Comparison between privacy in Europe and in the USA	3
1.1	Privacy Frameworks and Cultural Differences	3
1.1.1	Philosophical and Cultural Approaches to Privacy	3
1.1.2	Brief Comparison of Privacy Regulations	4
1.1.3	Cultural Impacts on Business Practices	5
1.2	Impacts on Risk Management	5
1.2.1	Operational Impacts of Privacy Compliance	5
1.2.2	Examples of Compliance Challenges	6
1.2.3	Risk Management Strategies	6
2	Expanding Operations Across Borders	7
2.1	Scenario 1: A European Company Expanding to the United States . . .	7
2.2	Scenario 2: A U.S. Company Expanding to Europe	8
3	Conclusions	8

1 Comparison between privacy in Europe and in the USA

While the need to protect personal data is widely recognized, approaches to privacy vary significantly between regions, as between Europe and the United States. These differences come not only from distinct legal frameworks but also from contrasting cultural and philosophical views on the importance of privacy.

In Europe, privacy is often regarded as a fundamental human right, preserved with laws such as the General Data Protection Regulation (GDPR). This comprehensive legislation establishes strict requirements for how organizations must handle personal data, emphasizing transparency, accountability, and the rights of individuals. By contrast, the United States adopts a more fragmented approach to privacy, relying on a mix of sector-specific laws and self-regulation. This reflects a broader cultural tendency to prioritize economic freedom and innovation over uniform privacy protections.

These contrasting approaches have significant implications for businesses, even in the area of risk management. Companies must navigate complex compliance requirements, balancing legal obligations with operational efficiency. For example, the widespread use of cookie banners in Europe illustrates the emphasis on obtaining clear user consent, while similar practices in the United States are often less stringent. Understanding these differences is critical for organizations operating across borders, as failure to address privacy risks can result in financial penalties, reputational damage, and a loss of consumer trust.

1.1 Privacy Frameworks and Cultural Differences

1.1.1 Philosophical and Cultural Approaches to Privacy

Europe views privacy as a fundamental human right, deeply rooted in its historical and cultural context. This perspective has influenced the development of laws like the General Data Protection Regulation (GDPR), which emphasizes protecting individuals from misuse of their personal data. The GDPR reflects a proactive approach, where privacy is built into the design of systems and policies, ensuring data protection is integral to all aspects of governance.

In contrast, the United States tends to treat privacy as a market-driven concern. Rather than adopting a unified national framework, the U.S. relies on several different sector-specific laws more or less tied together in the various cases, such as the Health Insurance Portability and Accountability Act (HIPAA) for healthcare and the California Consumer Privacy Act (CCPA) for consumer data. Moreover, privacy regulations often depend on the state. While there are federal laws like HIPAA or COPPA (Children's Online Privacy Protection Rule), individual states can have their own privacy laws, such as California's CCPA. This approach often emphasizes flexibility and innovation, allowing businesses to adapt their practices to specific industries while maintaining economic competitiveness.

1.1.2 Brief Comparison of Privacy Regulations

Key Features of GDPR:

- **Territorial Scope:** The GDPR applies to any organization processing the personal data of EU residents, regardless of where the organization is based.
- **Data Subject Rights:** Individuals have a range of rights, including the right to access, rectify, and erase their data.
- **Accountability:** Organizations must demonstrate compliance, maintain records, and conduct impact assessments for high-risk data processing activities.

US Privacy Approach:

- **Fragmented Laws:** Privacy regulations are sector-specific, leading to inconsistencies in protections across different industries.
- **Self-Regulation:** Many U.S. businesses rely on voluntary codes of conduct to manage privacy concerns.
- **Sectoral Focus:** Laws like HIPAA and CCPA target specific types of data or industries rather than providing comprehensive protections.

Conflicts and Harmonization Efforts: The differences between these approaches have led to challenges for businesses operating internationally. The now-invalidated EU-U.S. Privacy Shield, for instance, was an attempt to bridge the regulatory gap and facilitate data transfers. However, concerns over U.S. surveillance practices have led to the need for stronger agreements and more robust frameworks.

1.1.3 Cultural Impacts on Business Practices

Differences in cultural attitudes toward privacy influence how businesses handle data collection and user consent. In Europe, obtaining explicit user consent is central to compliance. Cookie banners, for example, are ubiquitous, visible and require users to actively agree to data tracking. This reflects the European emphasis on individual rights and transparency.

In the United States, cookie banners and similar tools are less strictly regulated. While businesses often provide privacy notices, these may rely on implied consent or provide fewer customization options for users. This approach aligns with the American emphasis on business flexibility and consumer choice, but it can lead to less consistent privacy protections.

1.2 Impacts on Risk Management

1.2.1 Operational Impacts of Privacy Compliance

Implementing privacy compliance measures can be costly and resource-intensive, especially for businesses operating in multiple jurisdictions. Under GDPR, organizations must invest in systems to ensure transparency, accountability, and data security. This includes conducting Privacy Impact Assessments (PIAs), training staff, and maintaining detailed records. Failure to comply can result in significant fines, up to 4% of global annual turnover, which creates a strong incentive for proactive compliance.

In the United States, compliance costs vary depending on the state and industry. Sectoral laws like HIPAA require specific protections for healthcare data, while laws like the CCPA in California mandate consumer rights such as data access and deletion. However, the fragmented nature of U.S. regulations means businesses often face less consistent enforcement and lower penalties compared to GDPR.

1.2.2 Examples of Compliance Challenges

Cookie banners are a prominent example of compliance challenges. In Europe, they are required under GDPR to obtain clear and informed user consent for data tracking. Businesses must ensure banners are user-friendly and provide options to opt-in or opt-out. By contrast, U.S. businesses often use less comprehensive approaches, relying on implied consent or generic privacy notices.

Third-party cookies present additional risks. European regulations require businesses to assess the impact of third-party tracking on user privacy, while in the U.S., such practices are typically less scrutinized. This difference can lead to increased exposure to privacy risks for companies that fail to adapt their practices to local regulations.

Data deletion is another aspect which is subject to careful practices and varies according to regulations. For instance, the GDPR in Europe enforces the "right to erasure" (right to be forgotten), requiring organizations to delete personal data upon request under specific conditions. In the United States, laws like the CCPA also grant consumers rights to request data deletion, though the requirements and scope differ across states and sectors.

1.2.3 Risk Management Strategies

In Europe, businesses are encouraged to adopt proactive strategies, such as embedding privacy-by-design principles into their operations. Robust data protection policies and regular audits are critical to maintaining compliance and minimizing risks. GDPR requires strict data protection measures, meaning that even any risk assessment or pen-test must ensure compliance with privacy and data security rules, particularly around handling personal data.

In the United States, risk management often focuses on contractual obligations and managing reputational risks. Businesses may prioritize compliance with key state laws, like the CCPA, and develop internal policies to address specific industry requirements.

For multinational organizations, aligning with global privacy frameworks (like ISO/IEC 27701 standard for privacy information management) can reduce complexity and enhance trust. Establishing consistent privacy policies across jurisdictions while respecting local regulations is key to mitigating risks and favoring long-term success.

2 Expanding Operations Across Borders

2.1 Scenario 1: A European Company Expanding to the United States

A European company opening a branch in the U.S. must adapt to the fragmented regulatory environment made of State-specific and sector-specific (if operating in certain industries) laws, privacy notices (that need to be adjusted to align to U.S. practices while maintaining clear communication with consumers), while establishing policies for data transfers and localization of data originated in Europe, using the Standard Contractual Clauses (SCCs) or other approved mechanisms. The company also needs to familiarize with state-specific data breach notification laws, which vary in reporting timelines and requirements compared to GDPR. For example:

- GDPR requires notification within 72 hours, while U.S. states range from 30 to 90 days.
- States like California mandate notifications to both affected individuals and the Attorney General if over 500 people are impacted.
- Penalties for non-compliance range from fines up to €20 million under GDPR, to \$750 per individual in California.
- Exemptions exist for encrypted data in both regions, but there may be other exemptions in other specific cases.
- GDPR applies to all companies processing EU data, while U.S. state laws apply based on resident location.

Some CCPA key articles to pay attention to:

- **Section 1798.120:** Consumers' Right to Opt-Out of Sale or Sharing of Personal information.
- **Section 1798.130:** Transparency Obligations and Process for Exercise of Individual Rights, with requirements for providing transparent privacy notices to consumers.



2.2 Scenario 2: A U.S. Company Expanding to Europe

A U.S. company establishing operations in Europe faces stricter privacy requirements. Key adaptations include:

- **GDPR Compliance:** Implement systems to manage explicit user consent, data subject rights, and accountability mechanisms. Develop privacy notices that meet GDPR's transparency standards.
- **Data Protection Officer:** Appoint a DPO if engaging in large-scale monitoring or processing of sensitive personal data.
- **Privacy Impact Assessments:** Conduct mandatory PIAs for activities posing high privacy risks, such as profiling or processing sensitive information.
- **Data Transfers:** Ensure compliance with GDPR-approved mechanisms for transferring personal data outside the EU, such as SCCs, Binding Corporate Rules (BCRs), or adequacy decisions.
- **Vendor Management:** Evaluate third-party processors and establish contracts that reflect GDPR requirements for data handling and security.

Some GDPR key articles to pay attention to:

- **Article 6:** Lawfulness of processing, specifying valid legal bases like consent or legitimate interest.
- **Article 25:** Data protection by design and default, requiring privacy measures to be integrated into systems.
- **Article 45:** Governs data transfers to countries with adequate protection standards.

3 Conclusions

With this small homework, I have highlighted the key differences between the concept of privacy in Europe and the United States, which is of fundamental importance for any

company looking to expand internationally. From this analysis, it seems that a U.S. company entering Europe would face greater challenges due to the strict data protection requirements of the GDPR, including stringent privacy rules, cross-border data transfer regulations, and detailed breach notification procedures. The need for comprehensive data handling practices, impact assessments, and compliance with EU consumer rights makes it a more complex transition. On the other hand, a European company entering the U.S. would need to navigate a variety of state (and sector) -specific laws, but overall, U.S. regulations tend to be less stringent than GDPR, making the challenges somewhat more manageable.